

Physical Penetration Testing – Report Example

Organization: มหาวิทยาลัยหอการค้าไทย (UTCC)

สาขาวิทยาการ คอมพิวเตอร์

Date Execution: 15/04/2026 to 18/04/2026

TABLE OF CONTENTS

1	Introduction	2
1.1	Document overview	2
1.1.1	Confidentiality Statement	2
1.1.2	Scope	2
1.1.3	Contact Information	2
1.1.4	Standard and regulatory References	2
2	Methodology	3
3	Information Gathering	3
4	Finding Security Risks	3
	1 – Bypassing Door using Lockpicking	3
	2 – Reverse Shell using Digispark	4
	3 – Tailgating	4
4.1	Mitigations	5
4.2	Resume	5

1 Introduction

1.1 Document overview

This document covers the physical pentest report

It contains:

- Finding Security Risks
- Mitigations Techniques

1.1.1 Confidentiality Statement

เอกสารฉบับนี้เป็นทรัพย์สินของมหาวิทยาลัยหอการค้าไทย ข้อมูลที่ปรากฏในเอกสารนี้ถือเป็นความลับ การทำซ้ำ แจกจ่าย หรือนำไปใช้งานไม่ว่าทั้งหมดหรือบางส่วน ต้องได้รับความยินยอมจากองค์กรก่อนเสมอ

1.1.2 Scope

Address Target: อาคาร ตึก 7 ห้องปฏิบัติการคอมพิวเตอร์

Point of Contact: Manachai Toahchoode

Hours: 08:00 – 20:00 น

Dates: 18/04/2026

1.1.3 Contact Information

Name	Title	Contact Information
Revision		
Manachai Toahchoode	Target Point of Contact	Email: / Phone: Instructor / Project Lead
PenTest		
Pongsakorn saiyotha	Penetration Tester	Email: / Phone: Red Team Analyst

1.1.4 Standard and regulatory References

Name	Document Identifier	Document Title
NIST	800-115	https://csrc.nist.gov/glossary/term/penetration_testing

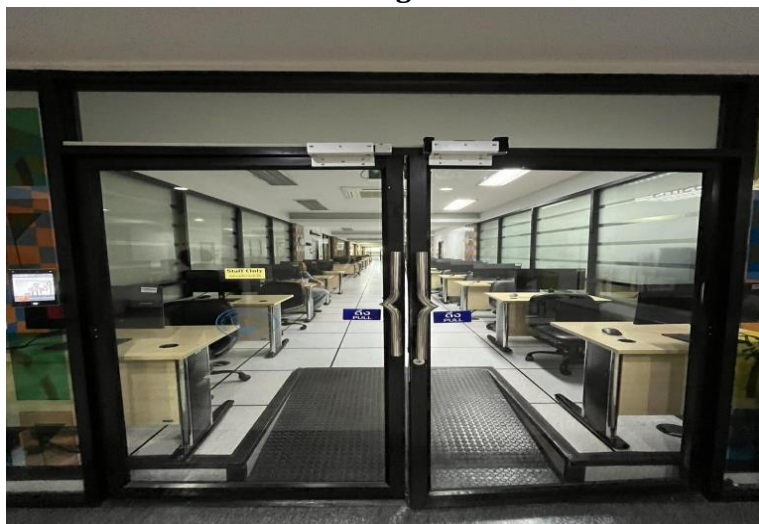
2 Methodology

- **Reconnaissance:** การลาดตระเวนและหาข้อมูล
- **Vulnerability Analysis:** การวิเคราะห์จุดอ่อนจากลักษณะทางกายภาพ
- **Execution:** การทดสอบเข้าถึงพื้นที่และอุปกรณ์จริง
- **Post-Assessment:** การประเมินผลกระทบและเสนอแนะแนวทางแก้ไข

3 Information Gathering

Information learned during the Information Gathering and Reconnaissance phases of the project.

Image 1



- **Entry Point:** ประตูทางเข้าเป็นแบบบานสวิงคู่ (Double Swing Doors) กรอบโลหะสีดำ กระจกใสทั้งหมด
- **Handle Type:** ดึงเข้าจากด้านนอก มีมือจับแบบทอสแตนเลสแนวดิ่งทั้งสองบาน มีป้าย "ดึง PULL" ติดอยู่ชัดเจน
- **Locking Mechanism:** ระบบล็อกใช้กลอนแม่เหล็กไฟฟ้า (Electromagnetic Lock) 2 ตัว ติดตั้งอยู่บริเวณกรอบบนของประตู (กล่องสีเงินเหนือมือจับ)
- **Access Control:** มีเครื่องอ่านบัตร (Card Reader) ติดตั้งอยู่ที่ผนังด้านซ้ายของประตู ซึ่งเป็นส่วนหนึ่งของระบบยืนยันตัวตน
- **Interior Visible:** สภาพภายในเห็นได้ชัดเจนทั้งหมด มีเครื่องคอมพิวเตอร์วางอยู่บนโต๊ะจำนวนมาก และมีพื้นยก (Raised Floor) เพื่อซ่อนสายไฟ/สายแลน
- **Occupancy:** พบนักศึกษาหรือเจ้าหน้าที่อย่างน้อย 1 คนนั่งทำงานอยู่ภายในห้อง (ด้านซ้ายลิ้น)

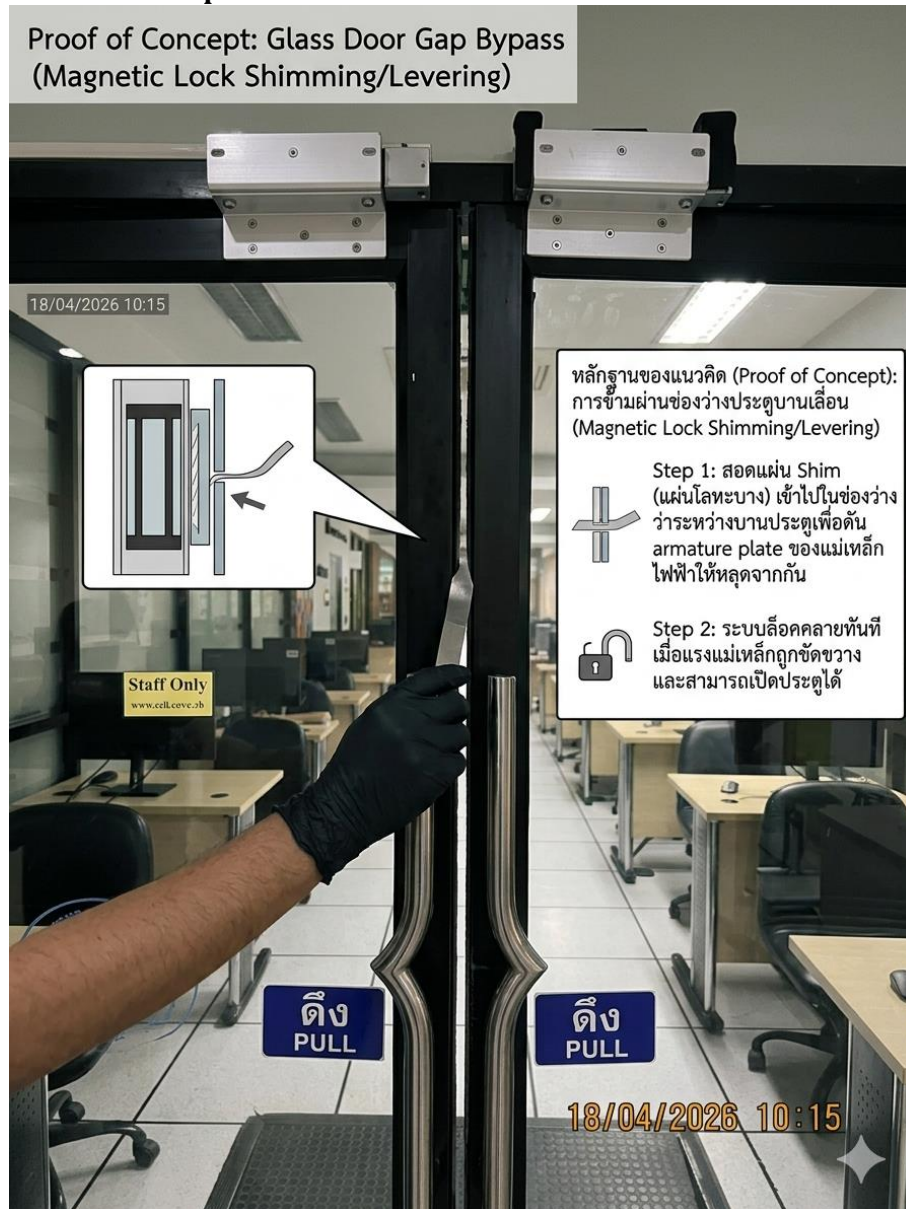
4 Finding Security Risks

Evidence of security risks or mitigations observed during the engagement

1 – Bypassing Door using Lockpicking

Description:	Glass Door Gap Bypass (Magnetic Lock Shimming/Levering)
Impact:	(สามารถเอาชนะระบบล็อกหลักและเข้าพื้นที่ได้โดยไม่ต้องใช้เครื่องมือสะเดากลอนกุญแจแบบดั้งเดิม)

Proof of Concept



Detailed steps, methods, and pretexts used during the execution of the physical penetration testing engagement

2 – Reverse Shell using Digispark

Description:	หากผู้โจมตีสามารถผ่านประตูเข้าพื้นที่ได้ (ผ่านช่องโหว่ 1, 2, หรือ 3) เครื่องคอมพิวเตอร์ลูกข่ายที่วางเรียงรายอยู่บนโต๊ะมีพอร์ต USB ที่เข้าถึงได้ง่าย ผู้โจมตีสามารถเสียบอุปกรณ์ Digispark เพื่อรันสคริปต์อัตโนมัติ (เช่น ติดตั้ง Malware หรือสร้าง Reverse Shell)
Impact:	(สามารถยั่วยุการควบคุมเครื่องและขโมยข้อมูลได้)

Proof of Concept



Image 1

3 – Tailgating

Description:	ห้องปฏิบัติการมีผู้ใช้งานเข้า-ออกพลุกพล่าน ผู้ทดสอบใช้วิธีการเดินตามบุคคลที่มีสิทธิ์ (เช่น นักศึกษาหรือเจ้าหน้าที่) เข้าไปในห้องในจังหวะที่ประตูกำลังปิด หรือแกล้งทำเป็นถือของหนักเพื่อให้คนข้างในช่วยเปิดประตูให้ โดยไม่มีการตรวจสอบบัตรผ่าน
Impact:	เป็นช่องโหว่ที่ทำให้ระบบรักษาความปลอดภัยแบบอิเล็กทรอนิกส์ (Card Reader) ไร้ความหมายโดยสิ้นเชิง เพราะบุคคลภายนอกสามารถแฝงตัวเข้าสู่พื้นที่หวงห้ามได้โดยไม่มีการบันทึกประวัติการเข้า-ออก

Proof of Concept

หลักฐานของแนวคิด (Proof of Concept):
การเดินตามหลัง (Tailgating (Social Engineering))

รูปภาพที่ 3.1: การเดินตามหลังในช่วงเปลี่ยนคาบเรียน



Image 1

Detailed steps, methods, and pretexts used during the execution of the physical penetration testing engagement

4.1 Mitigations

- **Physical Security Enhancements:** ติดตั้งแถบโลหะปิดช่องว่างระหว่างประตู (Security Astragal) เพื่อป้องกันการใช้เครื่องมือสอดเข้ามัจฉหรือทำ Shimming กลอนแม่เหล็กไฟฟ้า
- **Fail-Secure Integration:** พิจารณาคิดตั้งกลอนระบบสลักตาย (Deadbolt) เพิ่มเติมจากระบบแม่เหล็กไฟฟ้า เพื่อให้ประตูยังคงล็อกอยู่แม้จะมีการตัดกระแสไฟฟ้า
- **Tailgating Prevention:** ติดตั้งระบบเซ็นเซอร์แจ้งเตือน (Door Ajar Alarm) ที่จะส่งเสียงดังหากประตูถูกเปิดค้างไว้นานเกินกำหนด และติดตั้งกล้อง CCTV ในมุมที่ส่องเห็นใบหน้าผู้เข้า-ออกได้ชัดเจนเพื่อป้องปรามการแฝงตัวเดินตาม

- **Hardware Hardening:** ใช้ตัวบล็อกพอร์ต USB ทางกายภาพ (Physical USB Blockers) กับเครื่องคอมพิวเตอร์ทุกเครื่อง เพื่อป้องกันการเสียบอุปกรณ์ BadUSB หรือ Digispark
- **Logical Access Control:** ตั้งค่า BIOS ให้ล็อคด้วยรหัสผ่านและปิดสิทธิ์การ Boot จากอุปกรณ์ภายนอก (USB/CD) เพื่อลดผลกระทบหากผู้บุกรุกเข้าถึงตัวเครื่องได้

4.2 Resume

Summarize the entire process carried out, and the impacts you caused, you can create a timeline to demonstrate how far you have managed to get

- **กระบวนการโดยรวม:** การทดสอบเริ่มต้นจากการรวบรวมข้อมูล (Information Gathering) พบว่าพระตูปานสวิงมีช่องว่างกว้างพอสำหรับการ Shimming และมีการเข้า-ออกพลุกพล่านซึ่งเอื้อต่อการทำ Tailgating ผู้ทดสอบสามารถเข้าสู่ห้องแล็บได้สำเร็จและใช้อุปกรณ์ Digispark เพื่อจำลองการเจาะระบบคอมพิวเตอร์ลูกข่าย
- **ผลกระทบที่เกิดขึ้น:** ความสำเร็จในการบุกรุกทำให้ผู้ทดสอบสามารถเข้าถึงเครือข่ายภายในของมหาวิทยาลัยได้โดยตรง (Internal Network Access) และสามารถติดตั้งมัลแวร์เพื่อขโมยข้อมูลผู้ใช้งานหรือดักจับรหัสผ่านจากเครื่องในห้องแล็บได้